

Telco - Analyse de risques NMS et accès tiers

L'étude porte sur l'analyse des risques liés au système de supervision réseau de Telco et aux accès d'administration accordés aux tiers, notamment les fournisseurs et prestataires de maintenance. Elle vise à identifier les scénarios susceptibles d'affecter la continuité des services, la sécurité du SI et la maîtrise opérationnelle du réseau.

Le travail s'inscrit sur une période de six mois, correspondant à la durée nécessaire pour fixer les bases et effectuer une première analyse de risques sur le système étudié. Les ateliers EBIOS RM sont supposés réunir le RSSI, le responsable réseau, l'administrateur NMS, un représentant du SOC, le DSI, le responsable conformité ainsi que le responsable des fournisseurs, afin de garantir une vision partagée des enjeux métier et techniques.

Version: 0.1

Statut: Planifié

Atelier 1 - Cadrage et socle de sécurité

 Actifs

15

 Administration et configuration des équipements réseau Valeur métier Domaine: Global	 Authentification et gestion sécurisée des accès Valeur métier Domaine: Global
 Capacité de supervision et de détection des incidents en temps réel Valeur métier Domaine: Global	 Continuité des services Valeur métier Domaine: Global
 Bastion d'administration Support Domaine: Global	 IDS/IPS Support Domaine: Global
 Infrastructure BGP Support Domaine: Global	 LDAP / annuaire d'identités Support Domaine: Global
 MFA Support Domaine: Global	 NMS (système de supervision réseau) Support Domaine: Global
 Routeurs Support Domaine: Global	 SIEM Support Domaine: Global
 SOC Support Domaine: Global	 Serveurs d'orchestration Support Domaine: Global
 Switch Support Domaine: Global	

Evénements redoutés

9

Altération des journaux de sécurité

Gravité: Critique Actifs: Capacité de supervision et de détection des incidents en temps réel

Qualifications: Financier, Intégrité, Juridique, Opérationnel, Réputation

Altération des tables de routage provoquant une perturbation ou un détournement du trafic

Gravité: Critique Actifs: Continuité des services

Qualifications: Disponibilité, Financier, Intégrité, Juridique, Opérationnel, Réputation

Compromission de l'infrastructure d'authentification centralisée entraînant une perte de contrôle globale sur les accès d'administration

Gravité: Critique Actifs: Authentification et gestion sécurisée des accès

Qualifications: Disponibilité, Confidentialité, Financier, Intégrité, Juridique, Opérationnel, Réputation

Divulgaration d'informations sensibles relatives à l'architecture et aux configurations réseau

Gravité: Critique Actifs: Administration et configuration des équipements réseau

Qualifications: Confidentialité, Financier, Juridique, Opérationnel, Réputation

Déploiement d'une configuration erronée ou malveillante

Gravité: Critique Actifs: Administration et configuration des équipements réseau

Qualifications: Disponibilité, Financier, Intégrité, Juridique, Opérationnel, Réputation

Falsification des données de supervision conduisant à la prise de fausses décisions de pilotage opérationnel

Gravité: Critique Actifs: Capacité de supervision et de détection des incidents en temps réel

Qualifications: Financier, Intégrité, Juridique, Opérationnel, Réputation

Indisponibilité prolongée du NMS entraînant une interruption significative des services télécom

Gravité: Critique Actifs: Continuité des services Qualifications: Disponibilité, Financier, Juridique, Opérationnel, Réputation

Modification non autorisée des configurations réseau

Gravité: Critique Actifs: Administration et configuration des équipements réseau

Qualifications: Disponibilité, Financier, Intégrité, Juridique, Opérationnel, Réputation

Exploitation frauduleuse d'un compte administrateur tiers permettant la réalisation des actions malveillantes ciblées sur le NMS

Gravité: Important Actifs: Authentification et gestion sécurisée des accès

Qualifications: Disponibilité, Confidentialité, Financier, Intégrité, Juridique, Opérationnel, Réputation

Audits 3

Socle de sécurité – Guide d'hygiène ANSSI

ANSSI - Guide d'hygiène informatique - version détaillée

v1.0

Progression: 4%

2

Conforme

6

Partiellement conforme

0

Non conforme

0

Non applicable

192

Non évaluée

Statut: En cours

Socle de sécurité – ISO/IEC 27001:2022

International standard ISO/IEC 27001:2022

v1.0

Progression: 2%

0

Conforme

3

Partiellement conforme

0

Non conforme

0

Non applicable

120

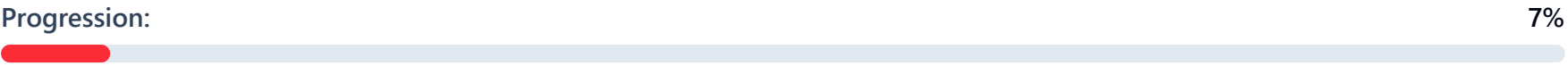
Non évaluée

Statut: En cours

Socle de sécurité – NIS2

v1.0

NIS 2 directive requirements



0 Conforme	1 Partiellement conforme
0 Non conforme	0 Non applicable
12 Non évaluée	

Statut: En cours

Atelier 2 - Sources de risques

Couples SR/OV

4

État - Mener des actions d'espionnage afin de collecter des informations stratégiques sur le NMS, les technologies utilisées

Motivation: Fort

Ressources: Illimité

Activité: Modérée

Pertinence: Très pertinent

Événements redoutés: Compromission de l'infrastructure d'authentification centralisée entraînant une perte de contrôle globale sur les accès d'administration

Justification: Les opérateurs télécoms sont régulièrement ciblés par des groupes étatiques à des fins d'espionnage. MITRE ATT&CK documente des groupes tels qu'APT5, GALLIUM et APT39 ayant ciblé le secteur des télécommunications y compris des équipements et infrastructures réseau. Ces observations CTI justifient un niveau d'activité élevé pour cette source de risque

Crime organisé - Obtenir un gain financier par extorsion, vol de données, déploiement de ransomware ou compromission d'infrastructures critiques

Motivation: Significatif

Ressources: Important

Activité: Important

Pertinence: Assez pertinent

Événements redoutés: Altération des tables de routage provoquant une perturbation ou un détournement du trafic, Déploiement d'une configuration erronée ou malveillante, Indisponibilité prolongée du NMS entraînant une interruption significative des services télécom, Modification non autorisée des configurations réseau, Exploitation frauduleuse d'un compte administrateur tiers permettant la réalisation des actions malveillantes ciblées sur le NMS

Justification: Le secteur des télécommunications est régulièrement ciblé par des groupes criminels organisés financièrement motivés, notamment dans le cadre d'opérations de ransomware ou de revente d'accès compromis. Les observations CTI récentes confirment une activité importante de ce type d'acteur dans ce secteur

Ancien employé - Divulguer des informations confidentielles à des concurrents ou sur internet à des fins financières

Motivation: Significatif

Ressources: Limité

Activité: Faible

Pertinence: Partiellement pertinent

Événements redoutés: Divulgateion d'informations sensibles relatives à l'architecture et aux configurations réseau

Justification: Bien que sa pertinence soit moyenne, l'ancien employé est retenu en raison de sa connaissance de l'environnement interne et d'une éventuelle conservation d'informations sensibles pouvant faciliter la réalisation d'actions malveillantes. Les écarts identifiés dans le socle de sécurité concernant la revue des habilitations renforcent la crédibilité de cette source de risque

Employé malveillant - Dissimuler des actions malveillantes en altérant les journaux et les données de supervision

Motivation: Significatif

Ressources: Limité

Activité: Faible

Pertinence: Partiellement pertinent

Événements redoutés: Altération des journaux de sécurité, Falsification des données de supervision conduisant à la prise de fausses décisions de pilotage opérationnel

Justification: Bien que sa pertinence soit moyenne, le collaborateur malveillant est retenu en raison de son accès légitime au système, de sa connaissance approfondie des processus internes et de sa capacité directe à agir sur les systèmes d'administration et les configurations réseau

Atelier 3 - Écosystème

Parties prenantes

4

Administrateur réseau (Autre)

Criticité actuelle

Criticité résiduelle

1

0.67

Mesures appliquées: Cloisonnement des réseaux, Authentification sécurisée, Droits d'accès, Droits d'accès privilégiés, Gestion des identités, Journalisation

Justification: Acteur interne clé disposant d'accès physiques et logiques privilégiés sur l'ensemble du cœur de réseau et du NMS

Equipe cyber (Autre)

Criticité actuelle

Criticité résiduelle

1

0.67

Mesures appliquées: Droits d'accès, Droits d'accès privilégiés, Gestion des identités, Journalisation

Justification: Administre le SIEM et le SOC avec des privilèges élevés sur les logs de sécurité

Fournisseur cloud (Fournisseur)

Criticité actuelle

Criticité résiduelle

2.25

1

Mesures appliquées: Authentification sécurisée, Sécurité de l'information dans les relations avec les fournisseurs, Surveillance, révision et gestion des changements des services fournisseurs, Gestion de la sécurité de l'information dans la chaîne d'approvisionnement des technologies de l'information et de la communication (TIC), Gestion des identités, La sécurité de l'information dans les accords conclus avec les fournisseurs

Justification: Héberge des briques critiques du SI d'administration (annuaires, bastions, sauvegardes)

Prestataire de maintenance réseau (Prestataire)

Criticité actuelle

Criticité résiduelle

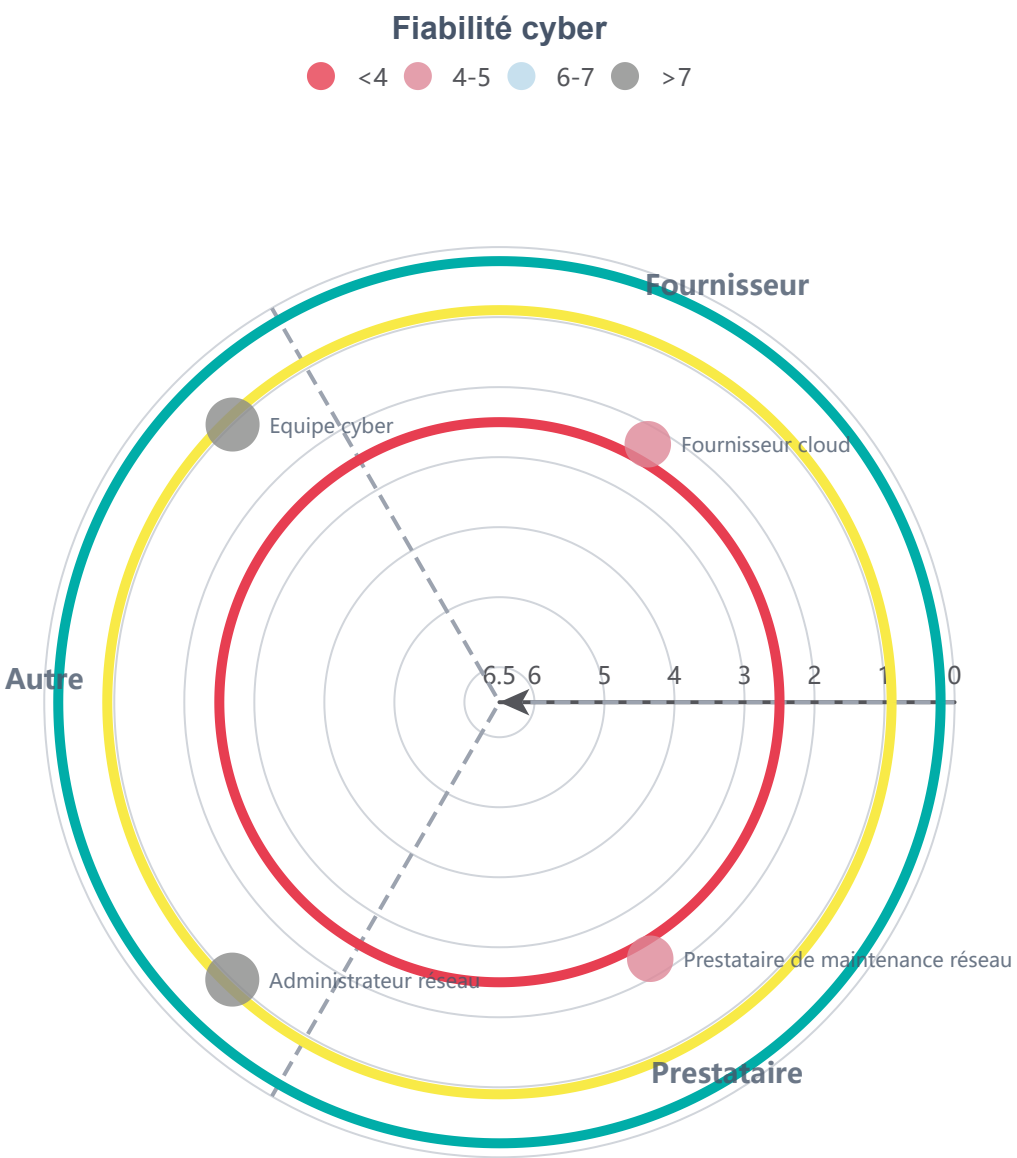
2.25

1

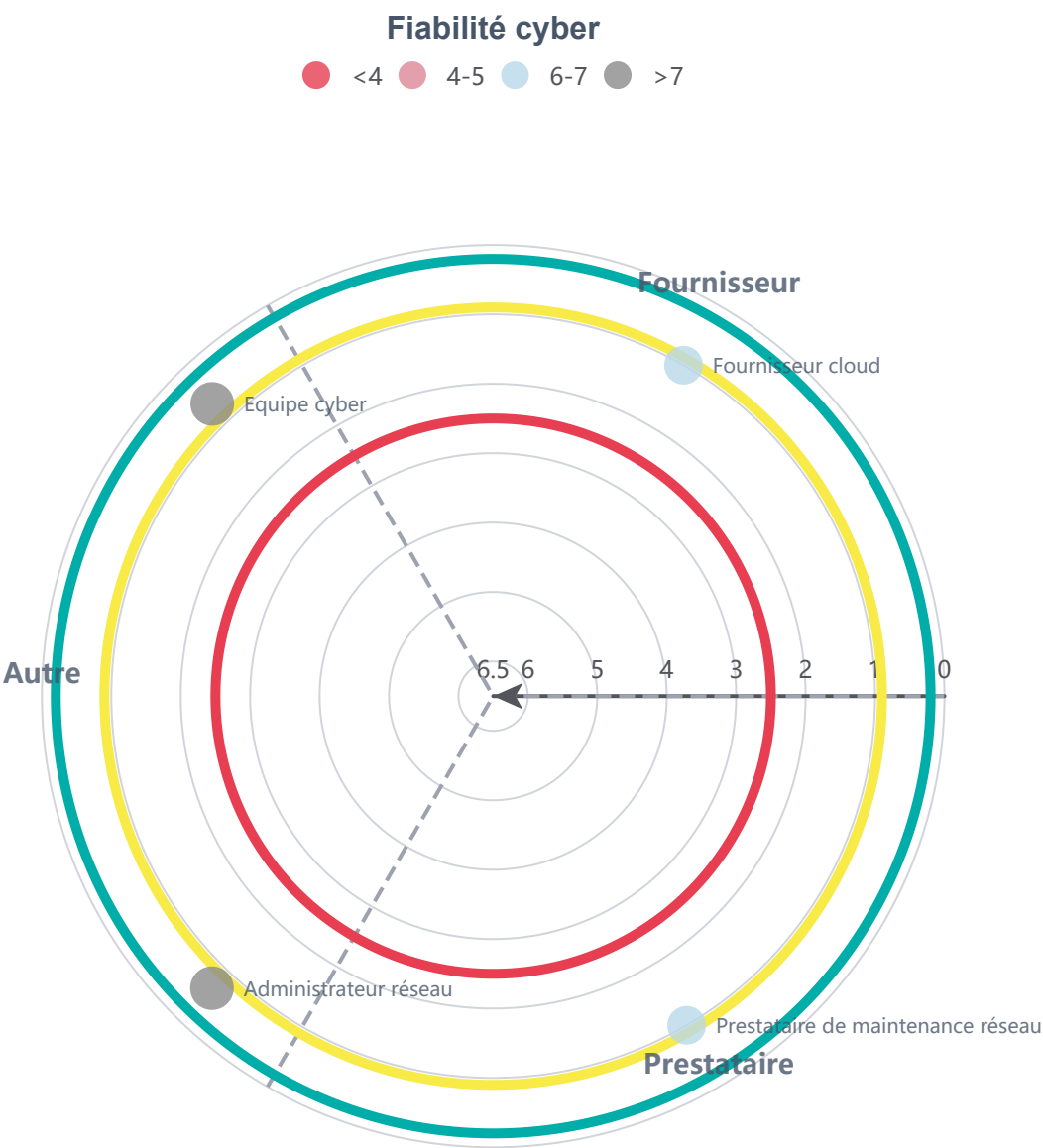
Mesures appliquées: Sécurité des services réseau, Cloisonnement des réseaux, Authentification sécurisée, Droits d'accès, Sécurité de l'information dans les relations avec les fournisseurs, Sécurité des réseaux, Gestion de la sécurité de l'information dans la chaîne d'approvisionnement des technologies de l'information et de la communication (TIC), Gestion des identités, La sécurité de l'information dans les accords conclus avec les fournisseurs, Journalisation

Justification: Dispose d'accès distants d'administration directs et privilégiés sur le NMS et les équipements.

Radar de l'écosystème - Actuel



Radar de l'écosystème - Résiduel



Scénarios stratégiques

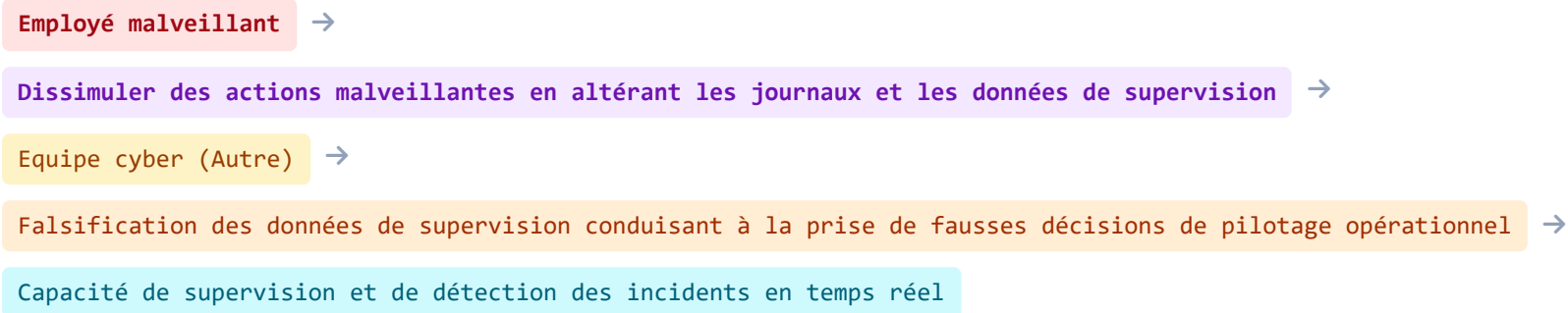
🔍 Altération de la supervision par un employé malveillant

Un collaborateur malveillant disposant d'un accès légitime aux outils de supervision de sécurité abuse de ses privilèges afin d'altérer ou supprimer les journaux de sécurité et de manipuler certaines informations de supervision, réduisant ainsi les capacités de détection et d'investigation de Telco

Gravité: Critique ID: SS5

🗺 Chemins d'attaque

Altération interne des journaux et données de supervision



Légende:

Source de risque

Objectif visé

Partie prenante

Événement redouté

Actif

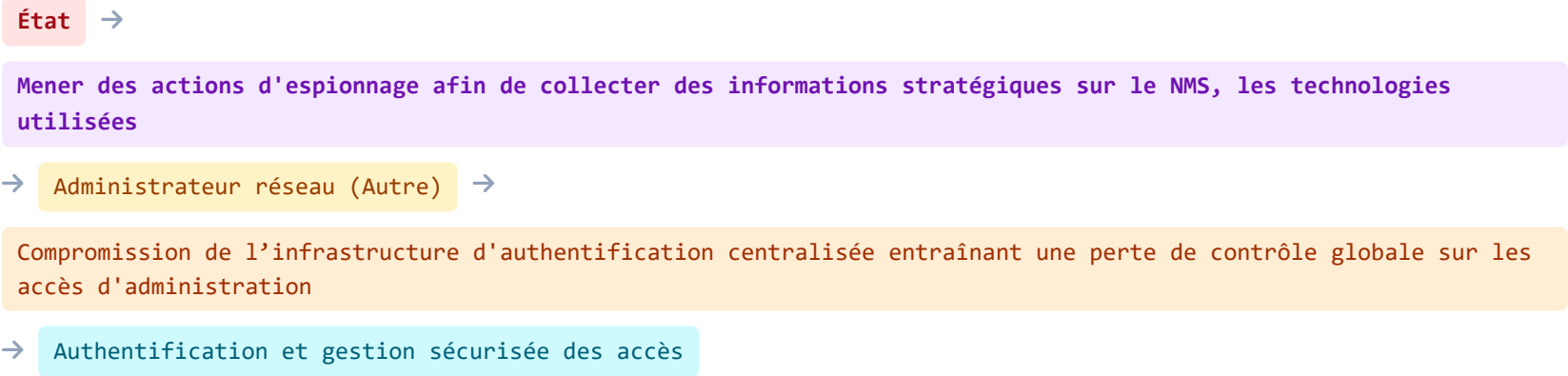
🔍 Compromission d'un administrateur réseau à des fins d'espionnage

L'APT compromet un administrateur réseau dans le but d'obtenir un accès privilégié au périmètre d'administration. Il utilise cet accès pour maintenir une présence durable lui permettant d'accéder aux ressources du NMS et de collecter des informations stratégiques sur l'infrastructure de Telco.

Gravité: Critique ID: SS4

🗺 Chemins d'attaque

Hameçonnage ciblé et vol de jetons de session d'administration



Légende:

Source de risque

Objectif visé

Partie prenante

Événement redouté

Actif

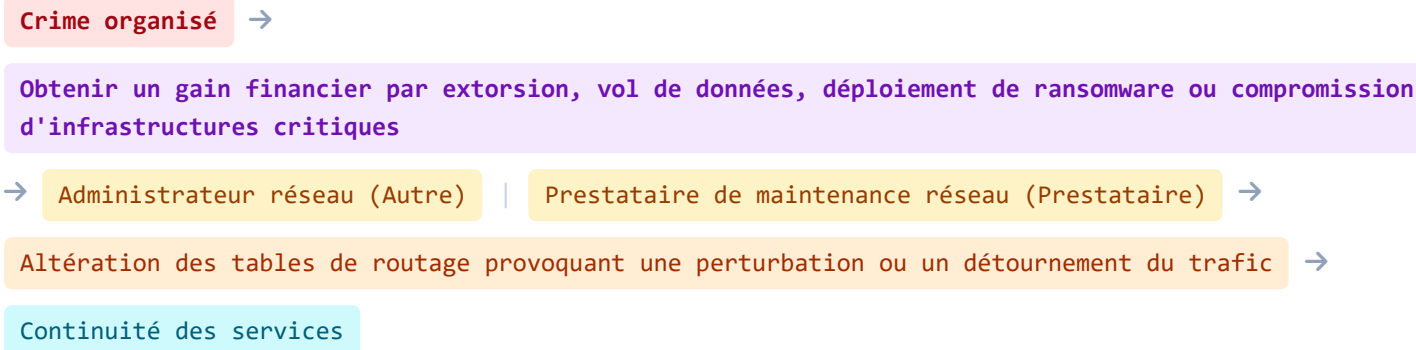
Compromission des accès de maintenance et altération des configurations réseau

L'attaquant compromet les accès d'un administrateur du prestataire de maintenance. Il utilise ses accès afin de modifier les configurations des équipements réseau, notamment les paramètres de routage, et peut déployer une configuration malveillante sur plusieurs équipements critiques provoquant ainsi une perturbations des services. Il exige une rançon en contre partie d'une restauration.

Gravité: Critique ID: SS2

Chemins d'attaque

Usurpation de session et injection de configurations malveillantes



Légende:

Source de risque Objectif visé Partie prenante Événement redouté Actif

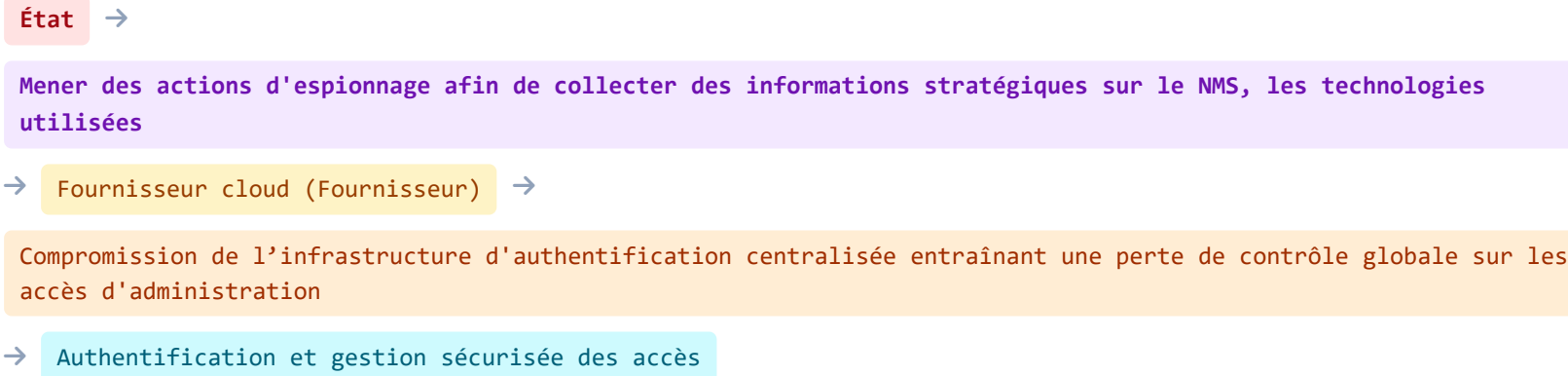
Compromission du fournisseur cloud et de l'infrastructure d'authentification

L'attaquant compromet le fournisseur cloud afin d'accéder aux environnements d'administration et à l'annuaire d'identités. Il exploite cet accès pour observer l'architecture, collecter des informations sur les comptes privilégiés et les mécanismes d'authentification dans le but de préparer une compromission en profondeur du système

Gravité: Critique ID: SS3

Chemins d'attaque

Compromission d'un compte cloud et collecte d'informations



Légende:

Source de risque Objectif visé Partie prenante Événement redouté Actif

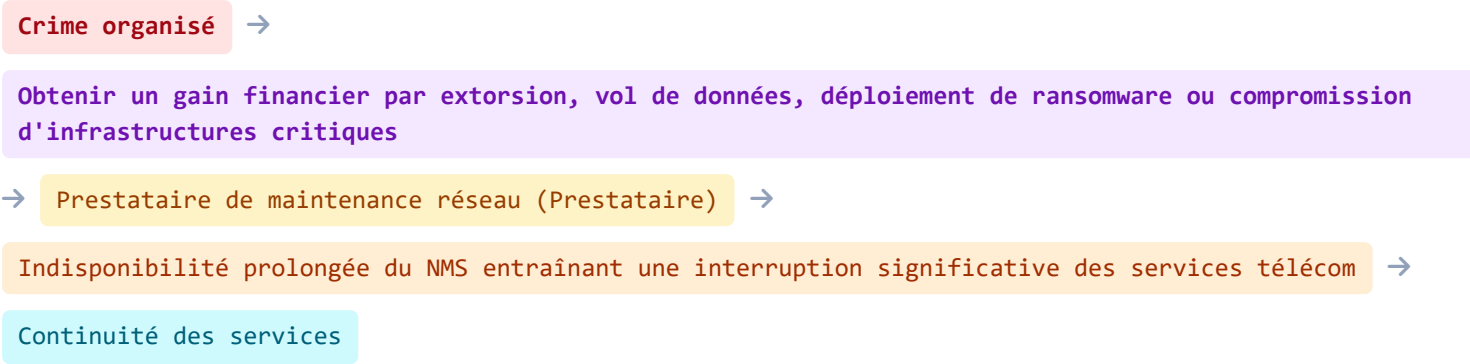
 Compromission du prestataire de maintenance et indisponibilité du NMS

Le groupe criminel compromet le prestataire de maintenance, puis utilise ses accès distants pour atteindre le NMS. Il cherche à chiffrer et rendre indisponibles les outils de supervision en provoquant une interruption des services et exiger une rançon en contre partie d’une restauration.

Gravité: Critique ID: SS1

 Chemins d'attaque

Compromission d'un accès tiers et déploiement d'un rançongiciel sur le NMS



Légende:

Source de risque

Objectif visé

Partie prenante

Événement redouté

Actif

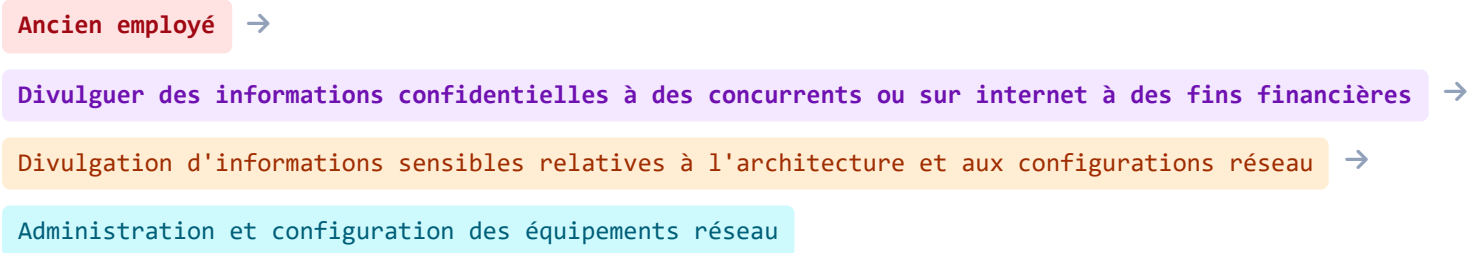
 Divulgarion d’informations sensibles par un ancien employé

Un ancien employé (administrateur réseau) ayant conservé des informations sensibles relatives à l’architecture ou aux configurations du réseau les divulgue à un tiers, entraînant ainsi une perte de confidentialité et pouvant faciliter la préparation d’attaques ciblées contre l’infrastructure de Telco

Gravité: Critique ID: SS6

 Chemins d'attaque

Divulgarion et revente de données sensibles



Légende:

Source de risque

Objectif visé

Partie prenante

Événement redouté

Actif

Atelier 4 - Scénarios opérationnels

Scénarios opérationnels

Méthode de cotation: Expresse

CA - SS5

Scénario stratégique: Altération de la supervision par un employé malveillant

Chemin d'attaque: Altération interne des journaux et données de supervision

Vraisemblance: Très vraisemblableGravité: Critique

Niveau de risque: Élevé

Parties prenantes: Equipe cyber (Autre)

Justification:

Le scénario est retenu car l’employé dispose déjà d’un accès légitime aux outils de supervision et peut abuser de ses privilèges. La falsification des données de supervision et l’altération des journaux peuvent réduire les capacités de détection et permettre la dissimulation d’actions malveillantes. Ajustement CTI non appliqué (règle R6) : source de risque interne, non couverte par ATT&CK.

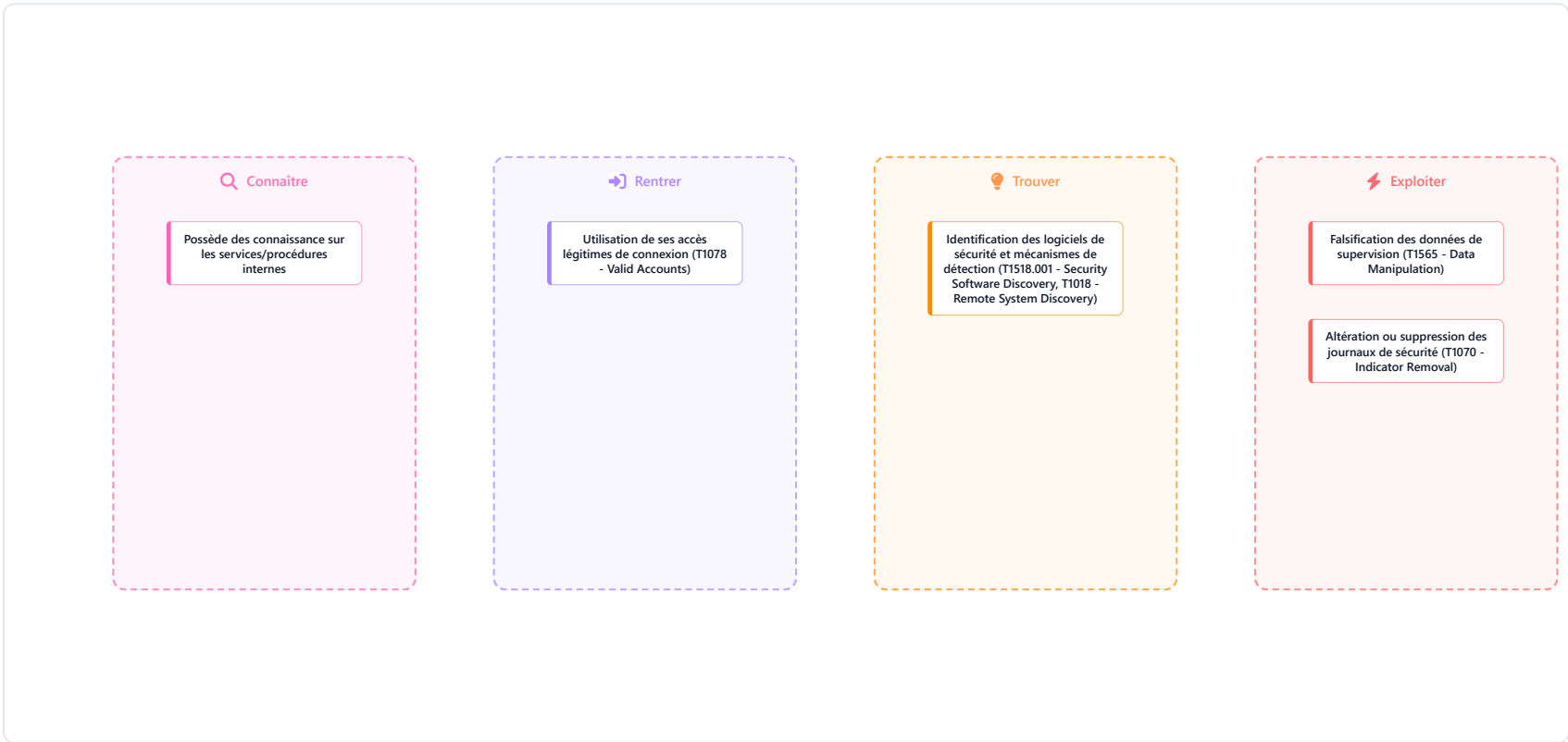
Modes opératoires

Abus des privilèges SOC et altération de la supervision

Un employé malveillant disposant d’un accès légitime aux outils SOC et SIEM abuse de ses privilèges pour identifier les mécanismes de détection, falsifier les données de supervision et altérer ou supprimer les journaux de sécurité. Ces actions réduisent la visibilité du SOC, la traçabilité des événements et les capacités d’investigation, permettant ainsi de dissimuler des activités malveillantes.

Vraisemblance: Très vraisemblableActions élémentaires: 5

Étape de l'enchaînement



CA - SS4

Scénario stratégique: Compromission d'un administrateur réseau à des fins d'espionnage

Chemin d'attaque: Hameçonnage ciblé et vol de jetons de session d'administration

Vraisemblance:

Très vraisemblable

Gravité:

Critique

Niveau de risque:

Élevé

Parties prenantes: Administrateur réseau (Autre)

Justification:

La compromission d'un compte administrateur peut permettre à un groupe étatique d'accéder durablement aux ressources d'administration et de collecter des informations stratégiques. L'utilisation d'un compte ou d'un jeton de session compromis facilite également la progression vers les ressources sensibles tout en utilisant une identité légitime. Réévaluée par la chaîne CTI (ATT&CK v19.2) : 8 techniques sur 8 observées

⚙ Modes opératoires

- **Hameçonnage d'un administrateur et exploitation de sa session**

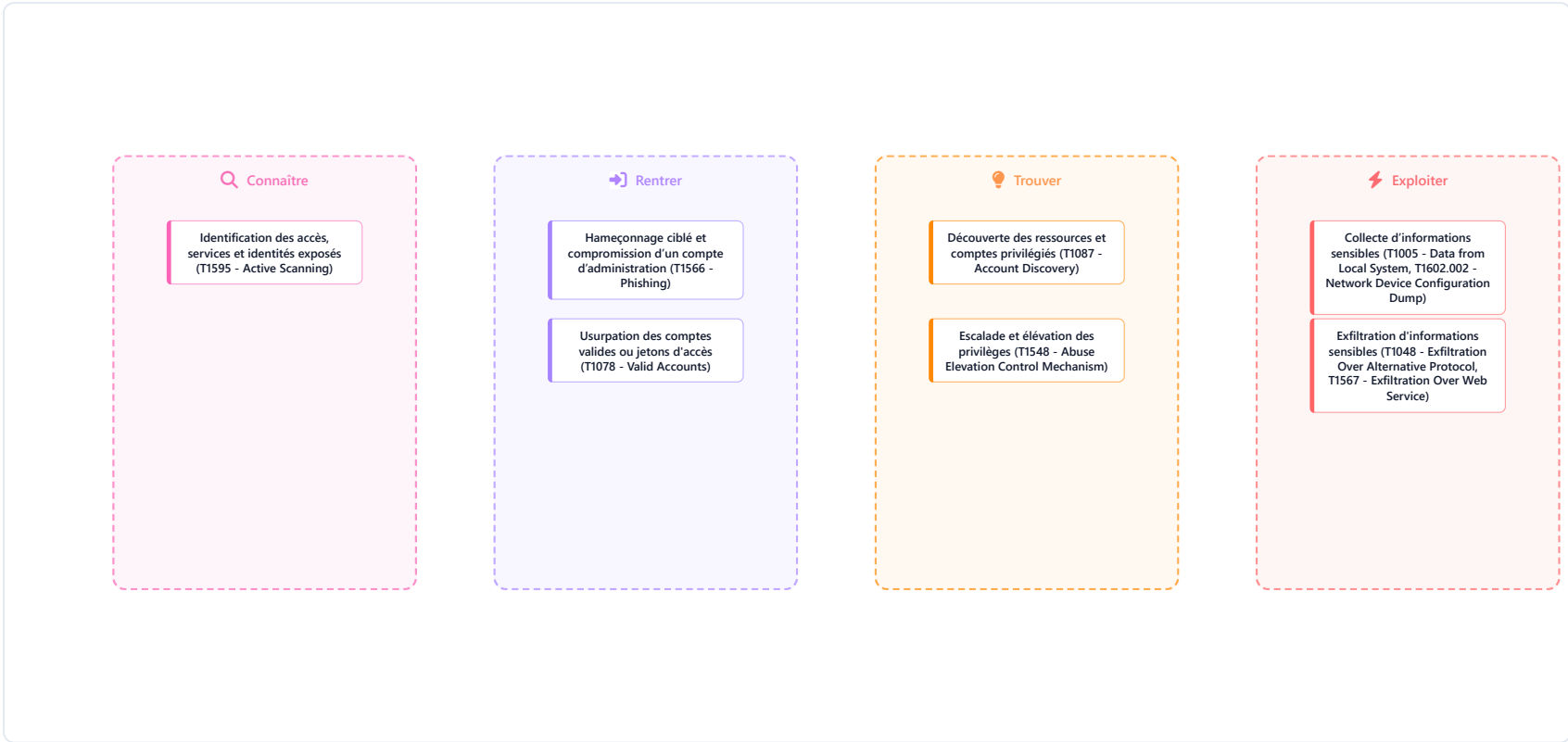
Un groupe étatique cible un administrateur réseau par hameçonnage afin de compromettre son compte ou son jeton de session. Il exploite l'identité compromise pour accéder au périmètre d'administration, identifier les ressources et comptes privilégiés et obtenir les droits nécessaires. Il collecte ensuite des informations stratégiques sur l'infrastructure et les mécanismes de sécurité avant de les exfiltrer à des fins d'espionnage

Vraisemblance:

Très vraisemblable

 Actions élémentaires: 7

Étape de l'enchaînement



⚙ CA - SS2

Scénario stratégique: Compromission des accès de maintenance et altération des configurations réseau

Chemin d'attaque: Usurpation de session et injection de configurations malveillantes

Vraisemblance:

Très vraisemblable

Gravité:

Critique

Niveau de risque:

Élevé

Parties prenantes: Administrateur réseau (Autre), Prestataire de maintenance réseau (Prestataire)

Justification:

Le scénario est retenu en raison des accès privilégiés nécessaires aux opérations de maintenance réseau. Leur compromission peut permettre la modification et le déploiement de configurations malveillantes sur des équipements critiques. Réévaluée par la chaîne CTI (ATT&CK v19.2) : 7 techniques sur 8 observées

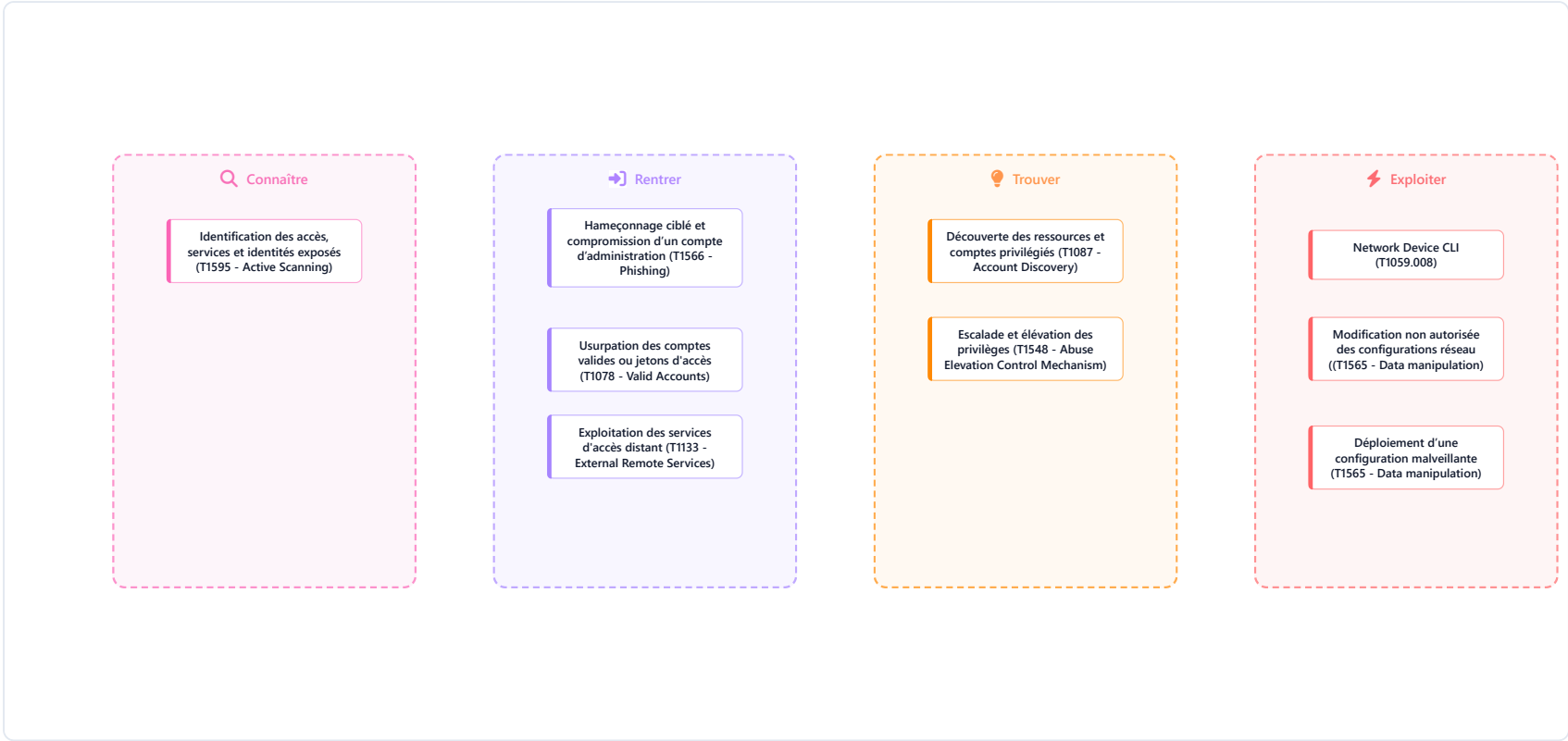
⚙ Modes opératoires

○ Usurpation d’un compte de maintenance et altération des configurations réseau

Un groupe criminel usurpe un compte utilisé par le prestataire de maintenance et exploite l’accès VPN/Bastion associé. Après avoir identifié les équipements accessibles et obtenu les privilèges nécessaires, il modifie les paramètres de routage et déploie une configuration malveillante afin de perturber ou détourner le trafic réseau

Vraisemblance: Très vraisemblable Actions élémentaires: 9

Étape de l'enchaînement



⚙️ CA - SS3

Scénario stratégique: Compromission du fournisseur cloud et de l'infrastructure d'authentification

Chemin d'attaque: Compromission d’un compte cloud et collecte d’informations

Vraisemblance: Très vraisemblable Gravité: Critique

Niveau de risque: Élevé

Parties prenantes: Fournisseur cloud (Fournisseur)

Justification:

Le scénario est retenu car la compromission d’un compte ou d’un jeton associé au fournisseur cloud peut fournir un accès aux ressources IAM et aux informations relatives aux identités privilégiées. L’exploitation de ces accès peut permettre à un attaquant disposant de capacités avancées de progresser vers les composants sensibles de l’infrastructure d’authentification Réévaluée par la chaîne CTI (ATT&CK v19.2) : 6 techniques sur 6 observées

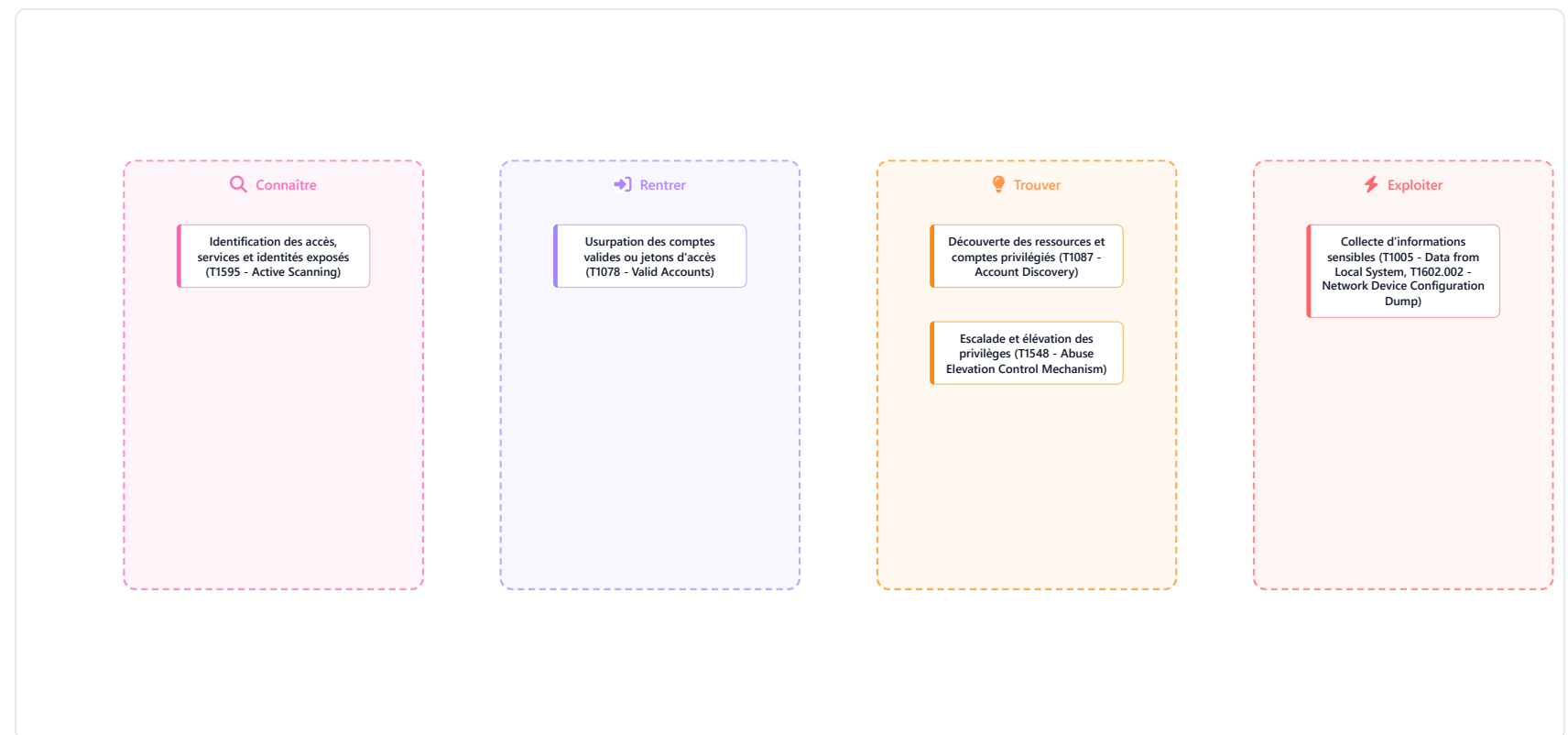
⚙️ Modes opératoires

○ Compromission d'un compte cloud et exploitation des accès IAM

Un groupe étatique compromet un compte d'administration cloud ou usurpe un jeton d'accès valide. Il exploite cet accès pour cartographier l'environnement IAM, identifier les comptes et ressources privilégiés et obtenir les droits nécessaires pour accéder aux composants sensibles de l'infrastructure d'authentification. Il collecte ensuite des informations sur les identités, les mécanismes d'authentification et les politiques IAM afin de préparer une compromission plus profonde du SI

Vraisemblance: Très vraisemblable **Actions élémentaires:** 5

Étape de l'enchaînement



CA - SS1

Scénario stratégique: Compromission du prestataire de maintenance et indisponibilité du NMS

Chemin d'attaque: Compromission d'un accès tiers et déploiement d'un rançongiciel sur le NMS

Vraisemblance: Très vraisemblable

Gravité: Critique

Niveau de risque: Élevé

Parties prenantes: Prestataire de maintenance réseau (Prestataire)

Justification:

Le scénario est retenu car le prestataire de maintenance dispose d'accès distants au périmètre d'administration. La compromission de ces accès constitue un chemin plausible permettant à un groupe criminel de progresser vers le NMS et d'en provoquer l'indisponibilité à des fins d'extorsion. Réévaluée par la chaîne CTI (ATT&CK v19.2) : 7 techniques sur 7 observées chez des groupes ciblant les télécommunications

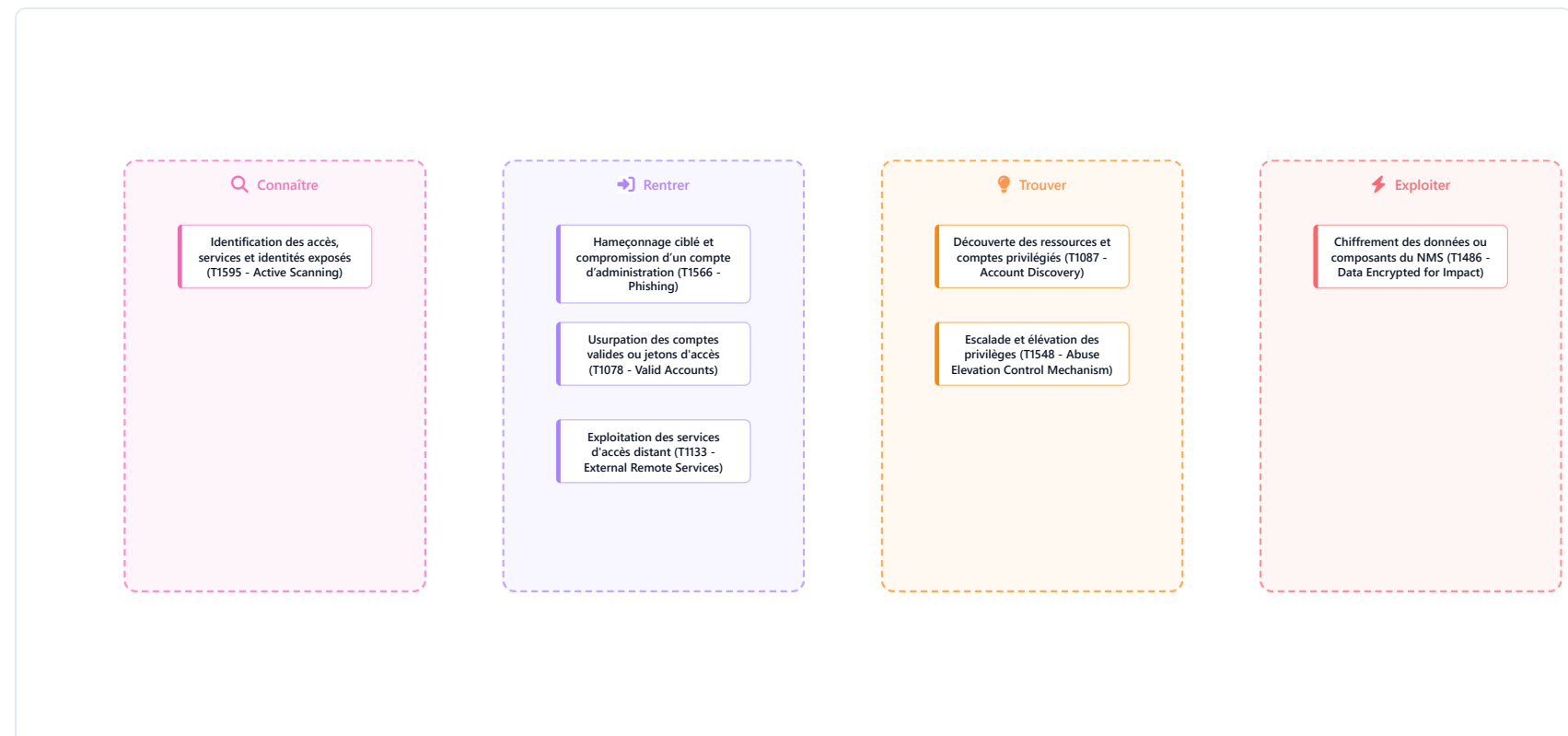
⚙ Modes opératoires

- Compromission d'un compte de maintenance via hameçonnage

Un groupe criminel cible un technicien du prestataire de maintenance afin de compromettre ses identifiants ou sa session. Il utilise ensuite le compte obtenu pour accéder au VPN/bastion de Telco, identifier les ressources accessibles et progresser vers le NMS. Après obtention des privilèges nécessaires, il déploie un rançongiciel afin de chiffrer les composants du NMS et d'en provoquer l'indisponibilité

Vraisemblance: **Très vraisemblable** Actions élémentaires: 7

Étape de l'enchaînement



CA - SS6

Scénario stratégique: Divulgarion d'informations sensibles par un ancien employé

Chemin d'attaque: Divulgarion et revente de données sensibles

Vraisemblance: Vraisemblable

Gravité: Critique

Niveau de risque: **Moyen**

Justification:

e scénario est retenu car un administrateur réseau peut disposer, dans le cadre de ses fonctions, d'un accès légitime à des informations sensibles relatives à l'architecture et aux configurations du réseau. La conservation ou l'exfiltration de ces informations avant son départ peut permettre leur divulgation ultérieure à un tiers, entraînant une perte de confidentialité et pouvant faciliter la préparation d'attaques ciblées. Ajustement CTI non appliqué (règle R6) : source de risque interne, non couverte par ATT&CK.

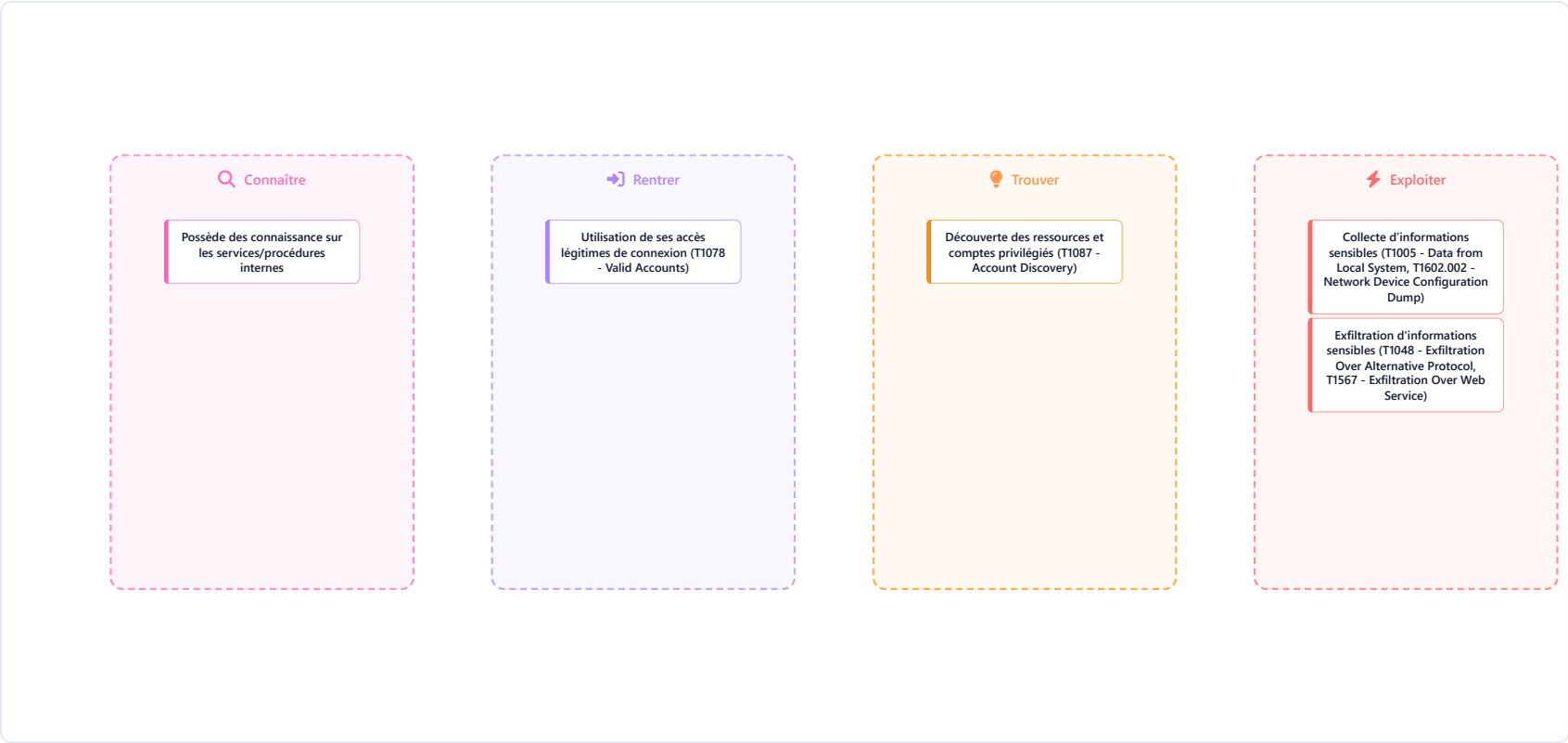
⚙ Modes opératoires

○ **Divulgation de données par un ancien employé**

Avant son départ de l’organisation, un administrateur réseau utilise ses droits légitimes pour collecter des informations sensibles relatives à l’architecture et aux configurations réseau. Il exfiltre ou conserve ces informations hors du SI puis, après la fin de son contrat, les divulgue, les transmet ou les revend à un tiers.

Vraisemblance: **Vraisemblable** Actions élémentaires: 5

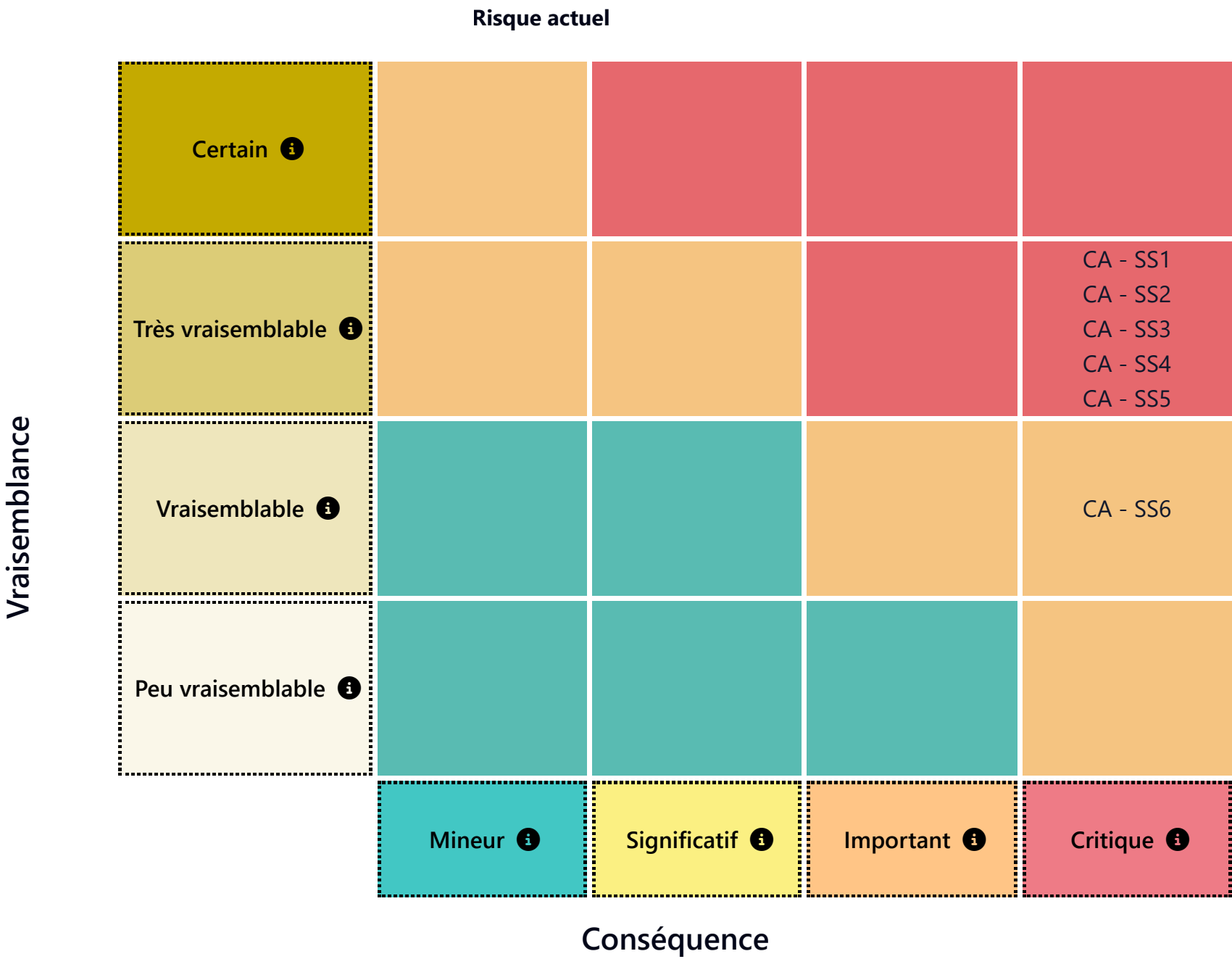
Étape de l'enchaînement

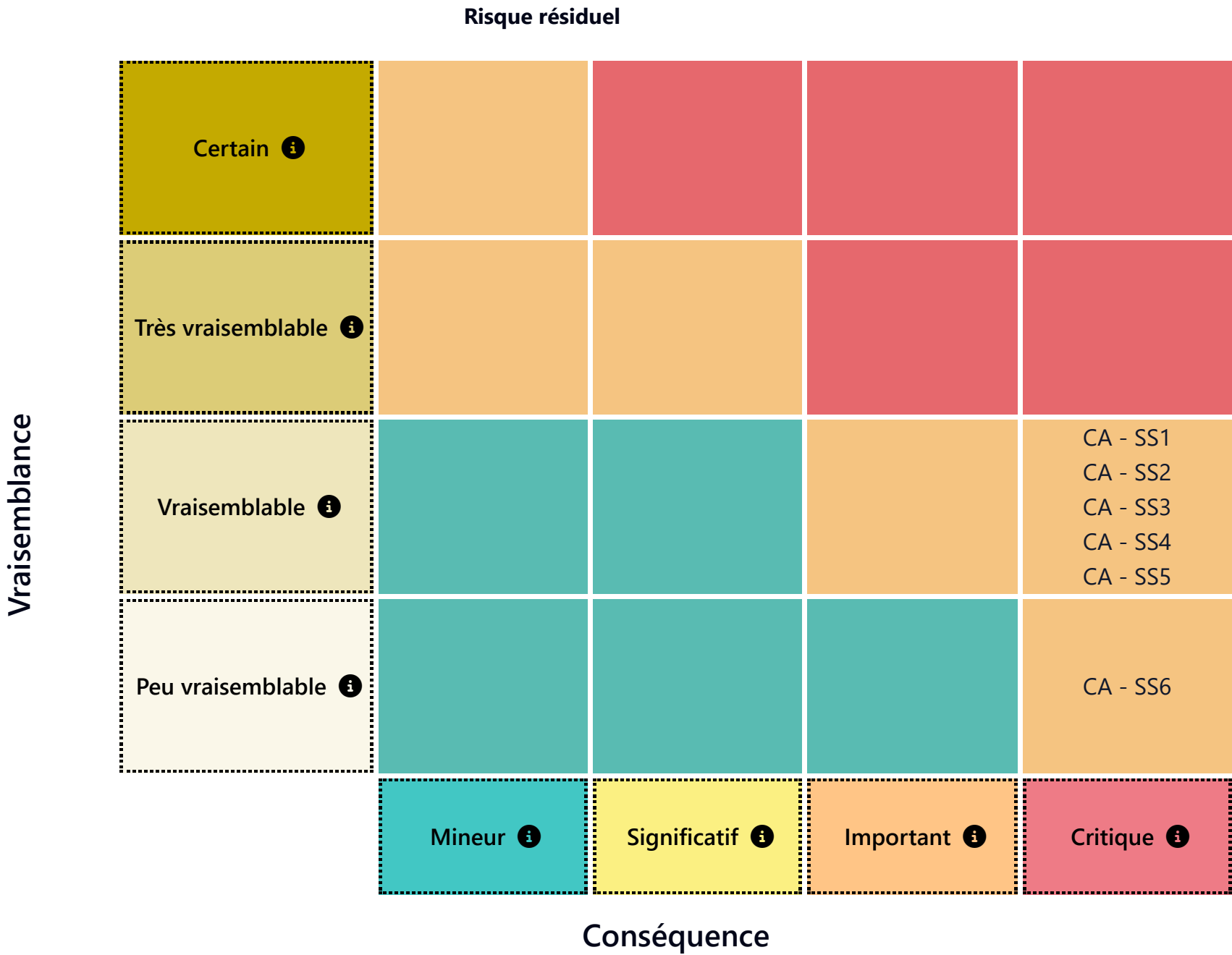


Atelier 5 - Synthèse et traitement du risque

Matrice de risque - Analyse de risques – NMS et accès tiers de Telco (v1.0)

ID	NOM	RISQUE ACTUEL	RISQUE RÉSIDUEL	TRAITEMENT
CA - SS1	Compromission du prestataire de maintenance et indisponibilité du NMS - Compromission d'un accès tiers et déploiement d'un rançongiciel sur le NMS	Élevé	Moyen	Atténué
CA - SS2	Compromission des accès de maintenance et altération des configurations réseau - Usurpation de session et injection de configurations malveillantes	Élevé	Moyen	Atténué
CA - SS3	Compromission du fournisseur cloud et de l'infrastructure d'authentification - Compromission d'un compte cloud et collecte d'informations	Élevé	Moyen	Atténué
CA - SS4	Compromission d'un administrateur réseau à des fins d'espionnage - Hameçonnage ciblé et vol de jetons de session d'administration	Élevé	Moyen	Atténué
CA - SS5	Altération de la supervision par un employé malveillant - Altération interne des journaux et données de supervision	Élevé	Moyen	Atténué
CA - SS6	Divulgence d'informations sensibles par un ancien employé - Divulgence et vente de données sensibles	Moyen	Moyen	Atténué





 Equipe cyber (Autre)

NOM	PRIORITÉ	STATUT	ASSIGNÉ À	ETA
Droits d'accès	--	--	--	--
Droits d'accès privilégiés	--	--	--	--
Gestion des identités	--	--	--	--
Journalisation	--	--	--	--

 Fournisseur cloud (Fournisseur)

NOM	PRIORITÉ	STATUT	ASSIGNÉ À	ETA
Authentification sécurisée	--	--	--	--
Sécurité de l'information dans les relations avec les fournisseurs	--	--	--	--
Surveillance, révision et gestion des changements des services fournisseurs	--	--	--	--
Gestion de la sécurité de l'information dans la chaîne d'approvisionnement des technologies de l'information et de la communication (TIC)	--	--	--	--
Gestion des identités	--	--	--	--
La sécurité de l'information dans les accords conclus avec les fournisseurs	--	--	--	--

 Prestataire de maintenance réseau (Prestataire)

NOM	PRIORITÉ	STATUT	ASSIGNÉ À	ETA
Sécurité des services réseau	--	--	--	--
Cloisonnement des réseaux	--	--	--	--
Authentification sécurisée	--	--	--	--
Droits d'accès	--	--	--	--
Sécurité de l'information dans les relations avec les fournisseurs	--	--	--	--
Sécurité des réseaux	--	--	--	--
Gestion de la sécurité de l'information dans la chaîne d'approvisionnement des technologies de l'information et de la communication (TIC)	--	--	--	--
Gestion des identités	--	--	--	--
La sécurité de l'information dans les accords conclus avec les fournisseurs	--	--	--	--
Journalisation	--	--	--	--

 Analyse de risques – NMS et accès tiers de Telco (Analyse de risque)

NOM	PRIORITÉ	STATUT	ASSIGNÉ À	ETA
Sensibilisation à l'hameçonnage	--	À faire	--	--
Gestion des mises à jour des équipements exposés	--	--	--	--
Revue des droits d'accès privilégiés	--	À faire	--	--
Journalisation	--	Actif	--	--
séparation des rôles au sein de l'équipe cyber	--	À faire	--	--
Révocation des accès au départ et revue des habilitations	--	À faire	--	--